Final Report

Course Name: MIS 170

Semester: Spring 2026

Instructor: Professor Aivazpour

Date Submitted: 05/18/26

Group Members

Robert Velazquez
Rithik Kumar
Kamran Khan
Abrahim Zadran
Jacob Boyd

Table of Contents

1. Title Page
2. Group Members
3. AI Usage Statement
4. Introduction
5. Part I: Cybersecurity Strategy & Risk Assessment

5.1 Identity & Access Management (IAM)

- User Authentication & Authorization
- IAM Policies
- Privileged Account Management
- Regulatory Compliance

5.2 Cryptography & Data Protection

- Protecting Data at Rest, In Transit, and In Use
- Encryption & Hashing Methods
- Securing Passwords, Databases, and Communications
- Legal & Regulatory Requirements

5.3 Network Security & Threat Mitigation

- Securing Internal & External Infrastructure
- Essential Security Measures
- Threat Prevention & Mitigation

- Security Monitoring

5.4 Risk Assessment & Compliance Strategy

- Biggest Cybersecurity Risks
- Security Frameworks & Standards
- Employee Security Awareness Training

5.5 Incident Response & Disaster Recovery

- Incident Response Plan (IRP)
- Disaster Recovery Strategies
- Business Continuity
- Cybersecurity Awareness Training

6. **Part II: Introducing the Cybersecurity Tool**
   - OWASP ZAP Overview
   - Features & Functionalities
   - Demonstration Summary
7. Conclusion
8. References
9. Timekeeping Table

No AI tools were used to generate the content of the report.

Introduction

ShopSphere is a mid-sized ecommerce company with 200-500 employees serving a global customer base mainly across the United States but also internationally. The company has seen rapid growth in the past 2 years while offering services such as customer account creation, saved payment methods, order tracking, shipment tracking, and product reviews and ratings. While being successful for now, ShopSphere faces many challenges involving security. This includes weak web app security, poor authentication, insecure data handling, lack of monitoring, and no incident response plan. This report presents a security strategy to address ShopSphere's vulnerabilities and establish a sustainable security framework aligned with industry standards.

Responses to Part 1

Identity And Access Management (IAM)

ShopSphere currently relies on password-only login with no form of multi-factor authentication and sessions that never expire. These deficiencies have directly contributed to the security vulnerabilities the company currently faces. In order to address these security issues, ShopSphere should implement MFA for all users, require a minimum of 12 characters for passwords, and configure a session time limit based on inactivity. The tools we would recommend is OAuth 2.0 and OpenID for single sign on which allow centralized identity management across the company's services. We recommend Keycloak as an open-source IAM solution to support the capabilities listed for ShopSphere.

Role-Based Access Control should be introduced using a least privileged model for users. There would be four roles: customer, merchant, administrator, and developer. Each role would

only have the bare minimum access required for their function, meaning a customer account should never have visibility into inventory or infrastructure. These access requirements should be reviewed and recertified on a quarterly bases to ensure that permissions remain appropriate as customers are gained and employees change or leave roles. All authentication events should be logged to a SIEM platform (SPLUNK) with real time anomaly detection enabled to flag suspicious login patterns such as brute force attempts.

Managing privileged accounts requires a higher level of expertise and standards then user accounts since these accounts have elevated access to sensitive data. ShopSphere should implement a Privileged Access Management (PAM) solution to govern and audit all privileged account activity. PAM tools enforce just-in-time access, meaning privileged credentials are only granted when needed and automatically revoked after use of these credentials (BeyondTrust, n.d.). All privileged sessions should be recorded and stored for audit purposes and no shared or administrative accounts should be permitted. All administrators should have a uniquely identifiable account so that all actions can be traced back to a specific admin. This is an essential function for both internal and external accountability following a security incident.

IAM plays a direct and measurable role in helping ShopSphere meet its regulatory obligations across multiple frameworks. Under the General Data Protection Regulation (GDPR), organizations are required to ensure that personal/sensitive data is only available to authorized personnel, which role-based access control and multi-factor authentication directly enforce by limiting and verifying who can access customer information. The California Consumer Privacy Act (CCPA) similarly requires that businesses implement reasonable measure to protect California residents and is a great framework to follow regarding ShopSphere’s IAM framework.

By centralizing identity management through Keycloak and maintaining a detailed access log in the SIEM platform, ShopSphere will be in a good position to produce audit trails and demonstrate compliance during regulatory reviews.

Cryptography and Data Protection

Given its nature as an online global service provider, ShopSphere possesses a large amount of highly confidential customer data. In order to make sure the information remains protected throughout the entire lifecycle, the company should introduce proper cryptography and security practices. When it comes to data at rest, it covers customer information kept on databases, backups, cloud storages, and servers of the corporation itself. The company should use AES-256 encryption to secure the information, and make sure encryption keys are also kept protected and updated. Database access should be limited to the principle of least privileges, which will allow employees accessing only information they need to do their job. When discussing data in transit, it refers to transferring information between users, different applications, and servers. TLS 1.3 protocol, as well as converting all the HTTP connections to HTTPS will make sure there are no packets intercepted in transit. Finally, data in use relates to information actively being used by the system or accessed by employees. Security measures here should include role-based access control, session timeout, endpoint protection, and monitoring of any suspicious activities. Customer data should be only accessible when it is really needed.

Furthermore, ShopSphere should apply modern algorithms and ciphers for ensuring proper system and network security. When securing stored data, AES-256 should be applied, whereas RSA and ECDH can be useful for encryption and key exchanges. Moreover, passwords should never be stored in plain text form, as ShopSphere should use bcrypt in order to generate

hashes. Salting should also be included, as it increases security. Finally, using SHA-256, integrity of messages and files will be ensured.

Cryptography plays an essential role when discussing password, database, and communications protection. A hashed password is harder to crack, while the databases themselves should be encrypted in order to make sure all the customer information is kept safe. Furthermore, the transmission of data should be made secure with SSL/TLS protocol, and safe API authentication should be introduced to prevent hijacking.

As far as ShopSphere acts as an international company, it is obliged to comply with certain cybersecurity regulations. For instance, GDPR implies protecting the personal information of EU citizens, as well as informing about any qualifying data breach within 72 hours. Similarly, CCPA requires taking reasonable steps to protect personal information of Californian citizens. Lastly, since ShopSphere handles credit card transactions, PCI-DSS v4.0 also applies.

Network Security and Threat Mitigation

Our company ShopSphere should look to set up a multi-layered network. The layers will be comprised of several security defenses such as VPNs, firewalls, and other network segmentation technologies. Considering that ShopSphere has a large amount of confidential customer information, the internal networks and systems will be kept separate from the front-end systems by using a DMZ. Lateral movement will no longer be available for attackers if these securities are in place. For external communications, HTTPS and TLS encryption will be utilized to minimize risk, along with the implementation of a VPN for employees when accessing

internal systems. The NIST states that in order to reduce the impact of cyberattacks, along with protecting sensitive data, network segmentation and having smart access controls are key.

As previously stated, there will be several security technologies such as VPNs and next generation firewalls for monitoring network traffic. Utilizing prevention systems such as NIPS and IPS technologies, will assist with catching suspicious activity and potential malware or vulnerability attacks. A next-gen firewall is useful, but implementing a web application firewall (WAF) will be significantly important for ShopSphere's infrastructure going forward. Since ShopSphere relies on web applications for logging in, handling payments, and allowing reviews on services; a WAF and SIEM system will help drastically reduce the impact of XSS attacks.

Using services such as Cloudflare will also be useful due to the high probability of DDoS attacks from attackers aiming for ecommerce platforms like ShopSphere.

We find that the best way to combat social engineering or physical attacks, specifically that of phishing and insider threats, is through employee training. This would increase awareness and with the addition of a strong email filtering system, there would be a far less chance of such attacks. Insider threats on the other hand won't be stopped by training alone, and instead there should be some degree of employee monitoring. Having employees at different privilege levels, in an almost "no trust" manner, would be beneficial for ShopSphere at an internal level.

The significance behind security monitoring is huge throughout all of network security, especially when capturing real time threats. SIEM programs in particular, have proven to be a necessity when controlling network traffic, analyzing questionable activity, or viewing system logs. Splunk is a great example of a SIEM platform that ShopSphere could use, since it collects logged information from systems like firewalls and VPNs. According to Splunks website, which

overlooks global data on cyber-threats, “continuous security monitoring improves an organization's ability to detect and respond to threats before significant damage can occur” (Splunk, 2023).

Risk Assessment and Compliance Strategy

Cybersecurity challenges for the ShopShere e-commerce platform include web application attacks, poor authentication, absence of monitoring, and incident response measures. The critical risks for ShopSphere and its e-commerce environment include cross-site scripting (XSS) and SQL injection. Attackers use malicious scripts to target unauthenticated input on the web page login, review, and checkout pages. Attackers steal customer information from web pages, sites, or even hack entire servers. An account takeover attack due to the use of the password for authentication purposes is another issue. Without multi-factor authentication, accounts are more susceptible to attacks without any extra layers of protection. In addition, ShopSphere stores payment information and personally identifiable information for clients. In this regard, data breaches should be prevented, especially since web pages use HTTPS addresses. HTTPS should be used for providing encryption and additional security measures to web pages. Also, the lack of a centralized logging system, monitoring system for intruders, and an incident response plan will make potential attackers remain unnoticed for longer periods of time, which is a significant security issue and flaw in the system.

To increase cybersecurity, it is recommended to rely on multiple security frameworks as well as follow compliance standards. To begin, we suggest that ShopSphere should adopt the National Institute of Standards and Technology framework, which includes five cybersecurity functions: Identify, Protect, Detect, Respond, and Recover. Next, the International Organization

for Standardization should be applied to create an Information Security Management System (ISMS). As ShopSphere uses online payments, PCI Security Standards are essential in terms of using encryption techniques, secure authentication, and frequent security testing. ShopSphere should also comply with GDPR and CCPA, since the organization operates internationally and works with the clients of both the EU and California. GDPR implies that any entity using or storing personal information about EU residents should be protected against data breaches and provide customers with certain privacy rights. Similarly to the EU, the California Consumer Privacy Act ensures that residents have additional control over their personal information stored by companies. In addition, the organization should follow recommendations of the OWASP Foundation to prevent XSS, SQL injection, and broken authentication.

To decrease the amount of potential cybersecurity challenges and improve security awareness, ShopSphere should create an employee cybersecurity training program. We recommend using annual cybersecurity awareness training and quarterly phishing simulations conducted for all employees. It is also important for employees to receive training after any cyberattacks or incidents. During training, it is absolutely crucial to educate employees on how to recognize phishing emails, suspicious links, and social engineering attacks. Quarterly phishing tests can also decrease the number of successful attacks. It is also important to conduct role-based cybersecurity training programs. Role-based training means that administrators, developers, and customer support representatives receive special training related to their respective roles. For instance, developers receive secure coding instruction, where they learn how to avoid web attacks such as XSS and SQL injection. Administrators should be trained on how to perform access control management and what steps to take if an incident occurs.

Incident Response and Disaster Recovery

In today's environment, organizations are exposed to numerous cybersecurity risks such as hacking, malware, data breach, etc. In order to combat such risks, organizations need a proactive approach. Disaster recovery plans (DRP) and incident response plans (IRP) will help corporations react quickly in case of any incidents(Onwubiko & Ouazzane, 2022). ShopSphere's IRP should provide a clear structure for identifying and recovering from cybersecurity incidents. This plan should include six phases of incident response which are preparation, detection/ identification, containment, eradication, recovery, and lessons learned (Ellis, n.d.). Employees must be educated on who to contact and what procedures to follow during a security incident. A well developed and documented IRP will help organizations reduce the damage done internally and externally while still maintaining compliance with regulations.

To be successful organizations should implement a variety of disaster recovery strategies to protect their vulnerable systems. Daily automated backups and off-site cloud storage are must haves to make sure systems can be restored from a different location. For ShopSphere we recommend weekly restoration testing, secondary data centers, and standby servers. The main recovery objectives are Recovery Time Objectives (RTO) and Recovery Point Objectives (RPO) to minimize the downtime and data loss that accumulate from security incidents. Organizations could also implement SOAR (Security Orchestration, Automation, and Response) platforms to automate threat detection, incident response workflows, and procedures for recovery. These disaster recovery strategies help organizations quickly restore operations from inevitable security incidents.

To ensure business continuity after a security breach or a system failure, ShopSphere must focus on restoring the critical e-commerce services such as the customer logins and shipment management. ShopSphere operates globally and a prolonged downtime could result in mass financial losses and reputational damage. The company should use hot standby servers, Content Delivery Network (CDN) failover routing, and secondary data centers to keep the platform running. An overlooked aspect of business continuity is for ShopSphere to maintain communication with the customer base to reassure users during an outage. Testing of these backup systems will help guarantee that operations can be resolved efficiently.

Cybersecurity awareness training is probably the most critical factor to how to improve incident response and reduce the human error that could occur within ShopSphere. Employees should receive regular training on recognizing various cybersecurity attacks. These include recognizing phishing attempts, suspicious activity, and password security. ShopSphere recommends quarterly phishing simulation and semi-annual tabletop exercises to help employees practice against cybersecurity incidents. ShopSphere should also provide an annual awareness training so that employees expand their knowledge from new and existing threats. Well-trained employees act as the first line of defense against cybersecurity attacks and training can help tremendously to bolster its effects.

Introducing the Tool (OWASP ZAP)

OWASP Zed Attack Proxy also known as ZAP is a free open-source web application vulnerability scanner used to improve security. It is widely used by security professionals, or testers, and developers to find security vulnerabilities in their respectable systems. The tool was

developed to be accessible for both beginners and cybersecurity experts. This is done through its offerings of automated scanning and manual scanning capabilities. ZAP operates through two primary scanning modes which are passive scanning and active scanning. Passive scanning monitors traffic without modifying it, while active scanning probes the application for vulnerabilities by sending crafted requests (OWASP Foundation, n.d.). ZAP can detect vulnerabilities ranging from cross-site scripting (XSS) and cross-site request forgery to SQL injection.

ShopSphere was an ideal candidate for OWASP ZAP due to the company having no vulnerability scanning in place to protect against threats like cross-site scripting or SQL injection. To demonstrate the functionality of ZAP, we used a purposely vulnerable web application from one of our in-class exercises. We began by running a Spider scan to map all available web pages from the website, followed by an Active Scan. Following the scan, we headed to the alerts section of ZAP which flagged multiple findings with severity ratings. The web application contained high risk vulnerabilities such as XSS and SQL injections, the same 2 vulnerabilities that we practiced on the website. This verified the accuracy of ZAP to identify and analyze realistic security weaknesses. We were able to show how OWASP ZAP could be used to improve the security of a company's system and the method of doing so.

Conclusion

As ShopSphere develops into a leading ecommerce enterprise globally, implementing a cybersecurity strategy becomes inevitable due to the need to secure the information of customers, maintain operations, and ensure compliance with industry regulations. Some of the current

security problems that ShopSphere experiences include weak identity authentication, insecurity when handling data, absence of continuous monitoring, and lack of adequate incident responses. These security concerns can be addressed by applying robust IAM policies, encryption methods, network security layers, continuous training of employees, and proper incident responses.

Adoption of industry standards and frameworks such as NIST, GDPR, CCPA, PCI-DSS, and OWASP will enhance the security of ShopSphere. Use of monitoring tools like Splunk, key management systems such as Keycloak, network security services provided by Cloudflare, and web security tests from OWASP ZAP will also improve the security to the business. In summary, implementation of strong security strategies will help greatly when it comes to supporting the business in achieving its security objectives.

References:

BeyondTrust. (n.d.). *Privileged access management (PAM) glossary*. https://www.beyondtrust.com/resources/glossary/privileged-access-management-pam

Ellis, D. (n.d.). *6 phases of an incident response plan*. SecurityMetrics. https://www.securitymetrics.com/blog/6-phases-incident-response-plan

GDPR. “Complete Guide to GDPR Compliance.” *GDPR.eu*, 2025, gdpr.eu/.

National Institute of Standards and Technology. (2017). *Digital identity guidelines (NIST Special Publication 800-63-3)*. U.S. Department of Commerce. https://csrc.nist.gov/pubs/sp/800/63/3/upd2/final

Onwubiko, C., & Ouazzane, K. (2022). "SOTER: A Playbook for Cybersecurity Incident Management." *IEEE Transactions on Engineering Management*, 69(6), 3771–3791. https://doi.org/10.1109/TEM.2020.2979832

OWASP Foundation. (2024). *OWASP ZAP Documentation*. https://www.zaproxy.org/docs/

Splunk. (2023). *What is SIEM (Security Information and Event Management)?* https://www.splunk.com/en_us/data-insider/what-is-siem.html

zyBooks. (n.d.). *MIS 170A*. https://learn.zybooks.com/zybook/CSUSMIS170AivazpourSpring2026

Name of student	**Meeting date**	**Task**	**Other Notes**
Robert V	**Present**	**Completed**	**N/A**
Rithik K	**Present**	**Completed**	**N/A**

Kamran K	**Present**	**Completed**	**N/A**
Jacob B	**Present**	**Completed**	**N/A**
Abrahim Z	**Present**	**Completed**	**N/A**